



RiskQuant Product Demonstration Series

Scenario 1: Everyday Threats in Small Business Cybersecurity

Using financial modeling to understand phishing, stolen credentials, and operational downtime.

Bryon Mascher

December, 2025

[linkedin.com/in/bryonmaschercybersec](https://www.linkedin.com/in/bryonmaschercybersec)

github.com/DigiFenix777

This demonstration is part of the RiskQuant Product Demonstration Series — a set of real-world use cases that illustrate how Monte Carlo simulation and intuitive visualization can transform qualitative cybersecurity risk assessments into quantitative, financially actionable insights.

RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·
[linkedin.com/in/bryonmaschercybersec](https://www.linkedin.com/in/bryonmaschercybersec) · github.com/DigiFenix777

Table of Contents

1. SCENARIO CONTEXT	4
SECTION 2: RUNNING RISKQUANT	9
2.1 PRE-RUN SETUP IN RISKQUANT.....	9
ANNOTATION 1: CONFIGURE SIMULATION.....	10
ANNOTATION 2: INPUT DATA	11
ANNOTATION 3: QUANTIFY RISK	11
2.2 LOADING AND EXPLORING THE SMB DATASET	12
ANNOTATION 1: INPUT DATA	12
ANNOTATION 2: DOMAIN DROPDOWN	13
ANNOTATION 3: SCENARIOS BAR.....	13
ANNOTATION 4: PORTFOLIO SUMMARY AND DISTRIBUTION GRAPH	13
2.3 DOMAIN SELECTION	15
ANNOTATION 1: DOMAIN MENU	15
2.4 SCENARIO FILTERING AND DYNAMIC PORTFOLIO REFRESH	16
ANNOTATION 1: OPS DOMAIN SELECTED	16
ANNOTATION 2: SCENARIOS (OPTIONAL).....	16
ANNOTATION 3: UPDATED PORTFOLIO ANNUAL LOSS DISTRIBUTION	17
SECTION 3: INTERPRETING RISKQUANT RESULTS	18
3.1 PORTFOLIO ANNUAL LOSS DISTRIBUTION — ANALYZING THE PHISHING AND CREDENTIAL THEFT	
SCENARIO	18
ANNOTATION 1: SCENARIOS SET TO OPS-02	19
ANNOTATION 2: PORTFOLIO ANNUAL LOSS DISTRIBUTION VISUALIZATION	19
ANNOTATION 3: ANNUAL LOSS EXPECTANCY CALCULATION AND SIMULATION.....	20
ANNOTATION 4: DATA INSIGHTS BUTTON	20
3.2 DATA INSIGHTS PANEL — UNDERSTANDING PORTFOLIO METRICS	21
ANNOTATION 1 – DATA INSIGHTS PANEL (FULL VIEW):	22
3.3 CUMULATIVE PROBABILITY (CDF) – VISUALIZING CONFIDENCE AND RISK THRESHOLDS	23
ANNOTATION 1: UNDERSTANDING THE CDF.....	24
ANNOTATION 2 – P95 VALUE ON THE CURVE	24
ANNOTATION 3: P50 VALUE ON THE CURVE.....	25
ANNOTATION 4 – DATA INSIGHTS BUTTON	25
3.4 DATA INSIGHTS PANEL – UNDERSTANDING THE CUMULATIVE DISTRIBUTION FUNCTION (CDF)	26
ANNOTATION 1: CUMULATIVE PROBABILITY (CDF) DATA INSIGHTS	27
3.5 DISTRIBUTION BY SCENARIO – COMPARING INDIVIDUAL RISKS	28
RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·	
linkedin.com/in/bryonmaschercybersec · github.com/DigiFenix777	

ANNOTATION 1: DISTRIBUTION VISUALIZATION (P95 DISPLAYED)	29
ANNOTATION 2: COMPARISON TYPE: BOX	29
ANNOTATION 3: HOVER CARD (OPS-02)	29
ANNOTATION 4: COMPARISON TYPE: VIOLIN	30
ANNOTATION 5: GENERATE PER-SCENARIO SAMPLES TOGGLE	31
ANNOTATION 6: SAMPLES PER SCENARIO (5,000)	31
ANNOTATION 7: VIOLIN GRAPH SHAPE.....	31
ANNOTATION 8: DATA INSIGHTS BUTTON	31
3.6 DATA INSIGHTS PANEL – DISTRIBUTION BY SCENARIO.....	32
3.7 RISK MATRIX (LIKELIHOOD × IMPACT) – VISUALIZING QUALITATIVE RISK FOUNDATIONS.....	34
ANNOTATION 1: RISK MATRIX VISUALIZATION	35
ANNOTATION 2: MEDIUM IMPACT × HIGH LIKELIHOOD CELL	35
ANNOTATION 3: DATA INSIGHTS BUTTON	36
3.8 DATA INSIGHTS PANEL – RISK MATRIX (LIKELIHOOD × IMPACT)	36
 SECTION 4: EXPORTING AND SHARING SIMULATION RESULTS	 39
 4.1 EXPORTING RESULTS – DOCUMENTING AND SHARING INSIGHTS	 39
ANNOTATION 1: EXPORT: DOWNLOAD PORTFOLIO SAMPLES (CSV)	40
ANNOTATION 2: EXPORT: DOWNLOAD RUN MANIFEST (JSON)	41
 SECTION 5: TRANSLATING INSIGHT INTO ACTION	 42
 5.1: SCENARIO-BASED TAKEAWAYS – SMB PHISHING AND CREDENTIAL COMPROMISE	 42
5.2 AUDIENCE-ALIGNED VALUE PROPOSITIONS.....	43
5.3 WHAT’S NEXT – EXPANDING THE RISKQUANT SCENARIO SERIES.....	43
AUTHOR’S NOTE.....	45
 SECTION 6: SOURCES.....	 47

Executive Summary

Small businesses face the same cyber threats as large enterprises, but often lack the dedicated security teams, formal compliance programs, and large budgets necessary to manage them effectively. As a result, attacks that seem “small” or routine—such as a phishing email or a stolen password—can quickly escalate into expensive business disruptions.

This demonstration focuses on one of the most common and damaging scenarios affecting small organizations today: **a phishing attack that leads to credential compromise.**

A single employee accidentally entering their username and password into a fake login page can give an attacker access to email, billing platforms, cloud storage, customer records, or payroll systems. From there, even modest misuse can cause:

- Lost revenue from downtime
- Unauthorized transfers or fraudulent invoices
- Exposure of sensitive customer or employee data
- Reputational harm that impacts trust and sales
- Cleanup, legal, and recovery costs

Industry data highlights how widespread and costly this threat has become:

- According to the *Verizon 2024 Data Breach Investigations Report* [1], 68% of breaches in small organizations involve the use of stolen credentials.
- Small and mid-market organizations now face an **average breach cost of \$4 million**, based on the *IBM Cost of a Data Breach Report 2024* [2].
- Phishing remains the **top initial access vector** for attackers targeting small and resource-constrained businesses.

This demo utilizes **RiskQuant**, a Monte Carlo–powered risk analysis tool, to illustrate how a simple phishing attack can result in a wide range of potential financial outcomes—from minor inconvenience to significant business disruption. Instead of relying on guesses or technical jargon, RiskQuant turns this scenario into **clear, dollar-based insights** that small business owners can understand and act on.

The goal of this demonstration is simple:

To help small businesses see how everyday cyber risks translate into real financial impact, and to show how data-driven modeling can guide smarter decisions about training, protection, and resilience.

1. Introduction & SMB Threat Landscape

Small businesses operate in an increasingly digital world, relying on cloud-based email, online accounting platforms, customer portals, and remote-access tools to keep their daily operations running smoothly. However, with this convenience comes increased exposure: attackers now target small organizations more aggressively than ever—not because they are high-value targets, but because they are often **high-impact and have low defenses**.

According to Verizon's *2024 Data Breach Investigations Report*, **small organizations suffered more breaches involving stolen credentials (68%) than any other category of organization** [1]. Attackers rely on simple yet highly effective methods—such as phishing emails, fake login pages, and password reset scams—to quietly steal employee usernames and passwords. Once they have access, they can impersonate staff, view sensitive data, redirect payments, or lock systems to demand a ransom.

These attacks create real business disruption:

- **Email fraud and invoice scams** leading to unauthorized payments
- **Payroll or banking compromise** through account takeover
- **Downtime** caused by forced password resets, cleanup, and system recovery
- **Customer trust erosion** if personal or financial data is exposed
- **Unexpected expenses** related to IT support, legal fees, and lost productivity

For small organizations, the impact can be severe. IBM's *2024 Cost of a Data Breach Report* found that **small and mid-sized businesses experience an average breach cost of \$4 million globally**, a figure driven by lost revenue, operational delays, and recovery work [2]. Many of these incidents start not with sophisticated hacks, but with everyday human error—a single click on a well-crafted phishing message.

Threat actors targeting SMBs are not necessarily elite, nation-state groups. More commonly, they include:

- **Cybercriminal groups** using automated phishing kits and credential-harvesting tools
- **Business email compromise (BEC) actors** who specialize in invoice fraud and payroll diversion
- **Ransomware operators** who use stolen credentials as an entry point
- **Opportunistic attackers** scanning for weak passwords or unmonitored accounts

These attackers generally do not need advanced techniques—just a foothold. And for many SMBs, a compromised email account or cloud login *is* that foothold.

This demonstration models one of the most common and costly threats facing small businesses today:

A phishing-driven credential compromise that results in limited data exposure and operational downtime.

By simulating thousands of possible outcomes using Monte Carlo analysis, the RiskQuant dashboard illustrates the wide range of financial impacts—from minor, recoverable disruptions to severe, business-impacting events. For SMB owners and managers, this approach provides a clearer understanding of “what’s at stake” in tangible, dollar-based terms—without requiring deep cybersecurity expertise.

1.1 What RiskQuant Is — and Why It Was Built

Small businesses often struggle to understand their cybersecurity risks in clear, practical terms. Most tools, reports, and frameworks employ technical language, compliance jargon, or abstract “High/Medium/Low” ratings that hinder owners from making informed decisions.

RiskQuant addresses this issue

By converting cybersecurity risks into **easy-to-understand financial estimates** through a simple, interactive dashboard. Instead of guessing whether a threat is “serious,” SMB leaders can see:

- How much an incident might cost
- How often do different outcomes occur
- Which risks matter most
- Where a small investment could prevent a significant loss

It doesn’t require cybersecurity knowledge. It simply turns uncertainty into numbers that make sense to business owners.

1.2 What Monte Carlo Simulation Means (In Plain English)

Monte Carlo simulation may sound complicated, but the idea is simple:

It runs thousands of “what-if” scenarios to illustrate the range of possible financial outcomes resulting from a cyber incident.

Imagine rolling a pair of dice not once, but 20,000 times to understand the *true* odds of different outcomes. RiskQuant does the same thing—except with cyber risks instead of dice.

For each simulation, it asks:

- *How many incidents might happen this year?*
- *If one were to happen, how expensive might it be?*
- *What happens in a worst-case year? In a typical year?*

Then it aggregates all those results to show:

- **Expected Annual Loss (EAL)** — the average yearly impact
- **Median loss** — what a “typical” event looks like
- **Worst-case probabilities (p90/p95/p99)** — realistic severe outcomes

Unpredictable cyber incidents create significant financial uncertainty for SMBs. Some years have none. Some have one. Occasionally, something much worse. Monte Carlo simulation reveals the whole picture in a way that simple guesswork never can.

1.3 How RiskQuant Helps SMBs Make Smart, Budget-Conscious Decisions — Including Compliance Risks

Many small businesses operate with tight budgets and limited technical staff, so cybersecurity decisions often feel reactive or lower priority. However, even small organizations typically handle sensitive **customer or employee information**—such as names, email addresses, payment details, health information, addresses, or ID numbers.

If that data is compromised, the impacts go beyond technical cleanup.

Small businesses may unexpectedly face:

- **State-level breach notification requirements**
- **Customer communication obligations**
- **Contractual penalties from partners or vendors**
- **Fines or investigations, depending on the type of data involved**
- **Reputational harm that affects sales and retention**

Most SMB leaders are surprised to learn that many privacy and security laws—such as state data-protection statutes, consumer privacy regulations, and specific federal requirements—**apply regardless of company size** when personal data is involved.

RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·
linkedin.com/in/bryonmaschercybersec · github.com/DigiFenix777

RiskQuant helps SMBs understand these hidden costs by converting them into **plain financial terms**, showing how a single phishing attack or stolen credential can trigger:

- Customer notification expenses
- Consulting or legal fees
- Lost revenue from downtime
- Remediation and recovery costs

With this clearer picture, small businesses can prioritize affordable, high-ROI controls that reduce the likelihood and impact of these events, such as:

- Security awareness training
- Multi-factor authentication (MFA)
- Password managers
- Data backups
- Basic email and endpoint protection

These are practical steps that meaningfully reduce risk *and* help SMBs meet the expectations of customers, partners, insurers, and regulators—without requiring deep cybersecurity expertise.

In short:

RiskQuant empowers small businesses to make informed, financially grounded decisions that strengthen security, support compliance obligations, and protect long-term business stability.

2. Running RiskQuant

RiskQuant is a Python- and Streamlit-based application designed to help cybersecurity and GRC professionals translate qualitative risk registers into **quantitative, data-driven insight**. Using a Monte Carlo simulation, it models thousands of possible annual loss outcomes derived from each organization's defined risk scenarios.

For analysts and decision-makers alike, this turns uncertain estimates into measurable probabilities — revealing not just *what* could happen, but *how often* and *how costly* those outcomes may be. Executives gain financial visibility for budgeting and insurance decisions. At the same time, GRC teams can test the effect of controls, compare scenarios, and communicate risk in terms that resonate beyond the technical domain.

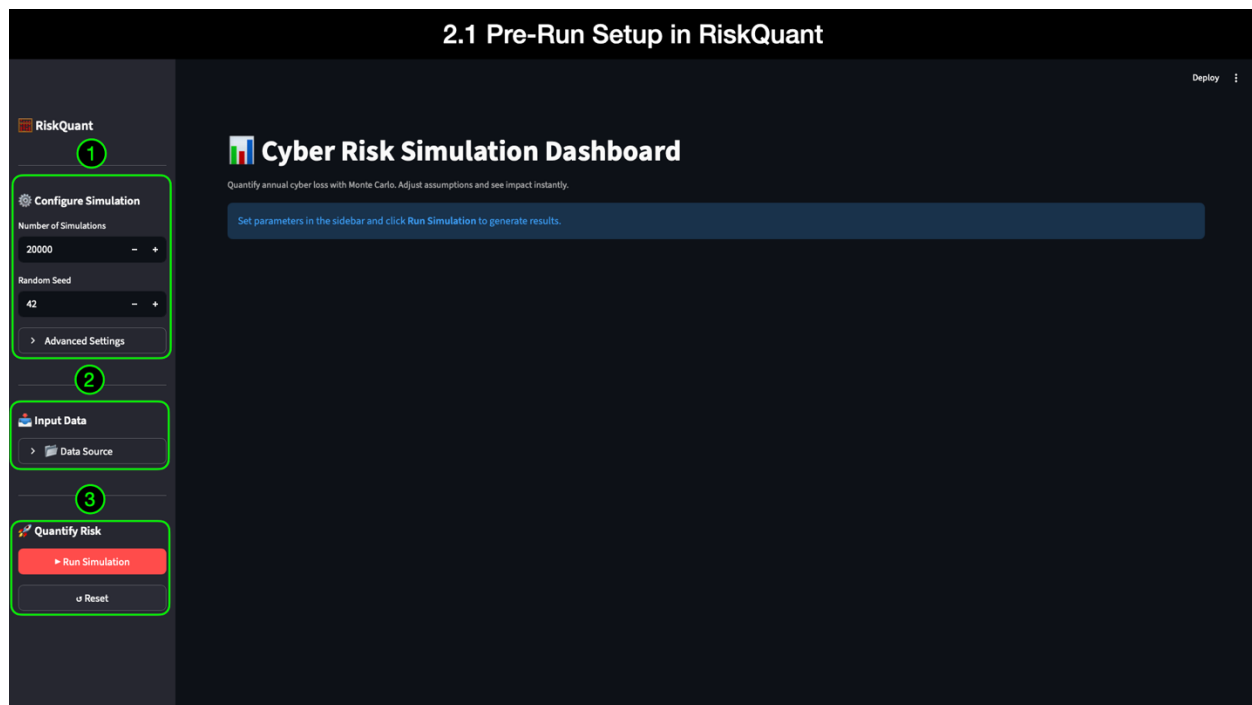
The process of running RiskQuant mirrors professional quantitative risk analysis workflows:

- **Configure** key simulation parameters.
- **Select** the appropriate data source or risk register.
- **Quantify** the modeled exposure through simulation.

The following annotated image introduces these core elements of the dashboard and the sequence an analyst follows to prepare a run.

2.1 Pre-Run Setup in RiskQuant

Before reviewing the simulation results, it is helpful to understand how **RiskQuant** conducts its Monte Carlo analysis. The dashboard **sidebar** acts as the analyst's control center, where users set simulation parameters, data sources, and run options before generating visualizations and insights. This process mirrors how quantitative risk analysts build models in professional settings by setting assumptions, defining data, and running controlled simulations that teams can repeat and audit later.



Annotation 1: Configure Simulation

At the top of the sidebar, the **Configure Simulation** section defines how RiskQuant performs its Monte Carlo sampling. Two key parameters drive the precision and reproducibility of the model:

- **Number of Simulations** — Each run generates thousands (or tens of thousands) of possible annual loss outcomes.
 - A higher number of simulations (e.g., 20,000–50,000) yields smoother, more statistically stable loss distributions, while smaller runs execute faster but with greater variability. This trade-off mirrors real-world risk modeling: more samples equal greater confidence but require more computation.
- **Random Seed** — The seed controls the pseudo-random number generator used to produce simulated loss values.
 - Setting the same seed ensures that results are **reproducible** — a critical feature for compliance, audits, or academic replication. Analysts can rerun the exact simulation later or alter the seed to explore the effects of random variability.
- **Advanced Settings** — Although not visible in the hero image, the **Advanced Settings** menu enables customization of the **displayed probabilities** (e.g., p50, p90, p95, p99) and **currency units** (default: USD). These controls adapt the dashboard to different reporting standards and audiences — analysts may prefer higher-

granularity tails (p99) for risk modeling, while executives may focus on p90–p95 for budget and insurance decisions.

Annotation 2: Input Data

Every simulation begins with data — in RiskQuant’s case, a **structured Excel-based risk register**.

The **Input Data** section in the sidebar specifies which dataset the dashboard uses. Each register represents a unique organizational context:

- **SMB:** compact register modeling small-business risks and MSP dependencies
- **Mid-Market:** broader register including internal IT and vendor scenarios
- **Enterprise:** complex, multi-domain register aligning to large-scale operational environments

RiskQuant reads the selected Excel file (e.g., `data/input/Risk_Register_Enterprise.xlsx`), validates its schema, normalizes columns, and derives simulation parameters (λ for frequency, loss min/mode/max for impact). This automation enables analysts to easily swap datasets without rewriting code, allowing for cross-organization comparisons or scenario testing with a single click.

Annotation 3: Quantify Risk

After configuring the parameters and data, the analyst starts the model using the **Quantify Risk** controls:

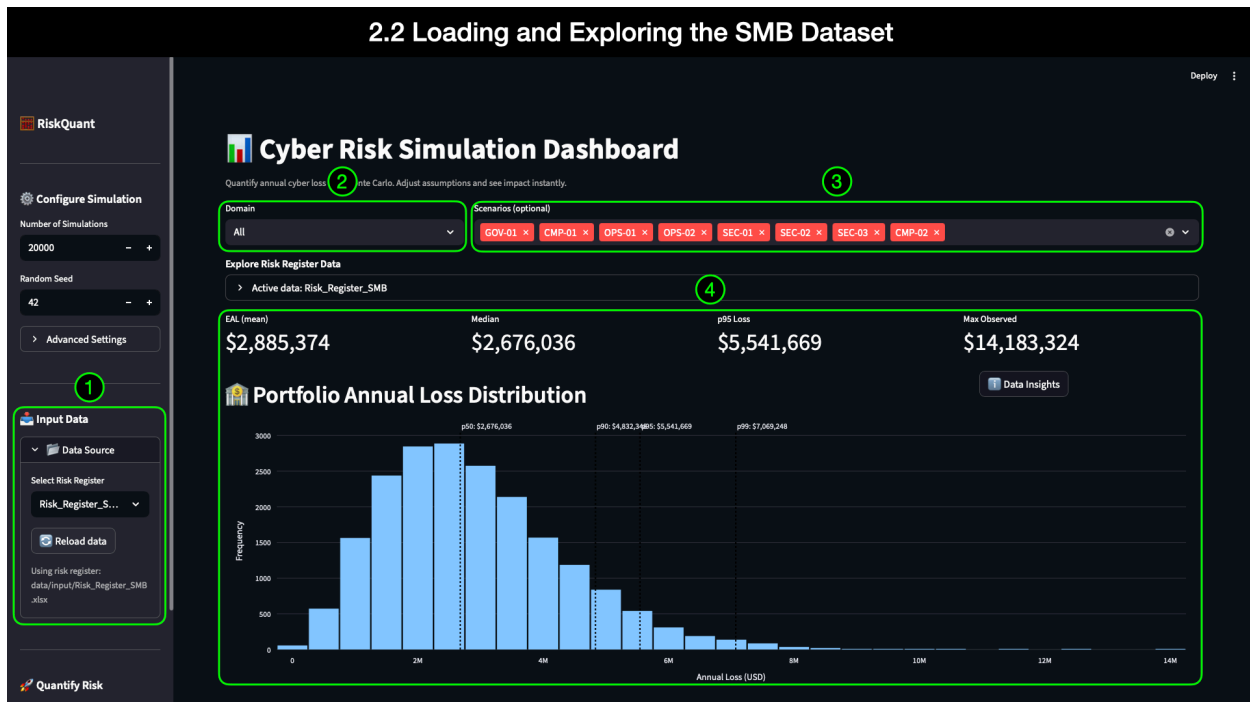
- **Run Simulation** — Executes the Monte Carlo engine, generating thousands of random samples per scenario and aggregating them into a portfolio distribution of annualized loss.
- **Reset** — Clears prior results, allowing a clean slate for new configurations or sensitivity analyses.

Together, these controls mark the transition from *setup* to *analysis*. In practical terms, clicking **Run Simulation** is where qualitative assumptions become quantitative evidence — where uncertain risk narratives transform into measurable financial outcomes.

2.2 Loading and Exploring the SMB Dataset

After configuration, RiskQuant uses the selected dataset—in this case, the **Small to Medium Business (SMB) Risk Register**.

This register models a smaller organization's cybersecurity landscape, characterized by moderate technical capacity, limited budgets, and a dependence on managed service providers and cloud vendors. The example below shows RiskQuant with the SMB register fully loaded and all scenarios visible in their default state.



Annotation 1: Input Data

At the top of the **Input Data** group in the sidebar, the analyst selects which Excel-based risk register to use.

Here, the user selects `Risk_Register_SMB.xlsx`, and the system confirms that it has successfully validated and loaded the file.

The application automatically normalizes column names, enforces data types, and derives simulation parameters — allowing the analyst to move seamlessly from data ingestion to modeling without manual preparation.

This step demonstrates one of RiskQuant's key values: flexibility.

Users can swap between SMB, Mid-Market, or Enterprise datasets with a single selection, enabling comparative or progressive analyses across organizational maturity levels, or evaluate organizational risk register datasets over time.

Annotation 2: Domain Dropdown

The **Domain** dropdown menu controls which high-level risk categories (for example, GOV, OPS, CMP, and SEC) the dashboard includes.

It defaults to **All**, meaning the entire register — every risk scenario in every category — is active in the current run.

In this state, the resulting visualizations reflect the *total portfolio risk* of the organization, representing the aggregate distribution of annualized loss across all defined threats.

(We will later narrow this view to the **OPS** domain in the following figure to explore operational risk in more detail.)

Annotation 3: Scenarios Bar

Beneath the domain filter, the **Scenarios** bar lists all active Risk IDs and their descriptions.

With *All* domains selected, every scenario appears in this list, providing the most comprehensive view of the organization’s exposure.

Analysts can deselect individual scenarios here to isolate particular threat types, such as phishing or MSP compromise, to observe their unique statistical signatures.

Annotation 4: Portfolio Summary and Distribution Graph

At the top of the main workspace, four **Key Risk Indicators (KRIs)** summarize the Monte Carlo results for the complete SMB portfolio:

Metric	Description	Current Value
EAL (Mean)	Expected Annual Loss — average simulated loss across all scenarios.	\$ 2,885,374
Median	50th percentile; half of the outcomes fall below this amount.	\$ 2,676,036
p95 Loss	95th percentile; upper-tail marker showing “bad but plausible” loss.	\$ 5,541,669
Max Observed	Largest loss observed in all simulated runs.	\$ 14,183,324

These figures form the baseline for comparison throughout the demonstration.

Below the metrics, the Annual Loss **(USD) Distribution** graph visualizes how often particular loss values occurred in the simulation.

The shape of the histogram conveys both **expected exposure** (the cluster around \$2.7 M) and **tail risk** (infrequent but severe events exceeding \$5 M).

This immediate visibility is what makes RiskQuant powerful: decision-makers can see, at a glance, the full range of financial outcomes their organization might face in a typical year.

For deeper technical insight:

For readers interested in the underlying mathematics, asset valuation models, and parameter derivation used in RiskQuant, please refer to the companion publication:

RiskQuant: Quantitative Cyber Risk Analysis with Monte Carlo Simulation
(*RiskQuant_White_Paper_Monte_Carlo_Cyber_Risk_Analysis.pdf*)

The white paper provides a detailed explanation of:

- How Monte Carlo simulation calculates Expected Annual Loss (EAL) and percentile-based tail metrics (p90–p99).
- How qualitative likelihood and impact ratings from frameworks such as NIST SP 800-53 and ISO 27005 are mapped to quantitative values.
- How the project derives synthetic asset valuations across SMB, Mid-Market, and Enterprise datasets.

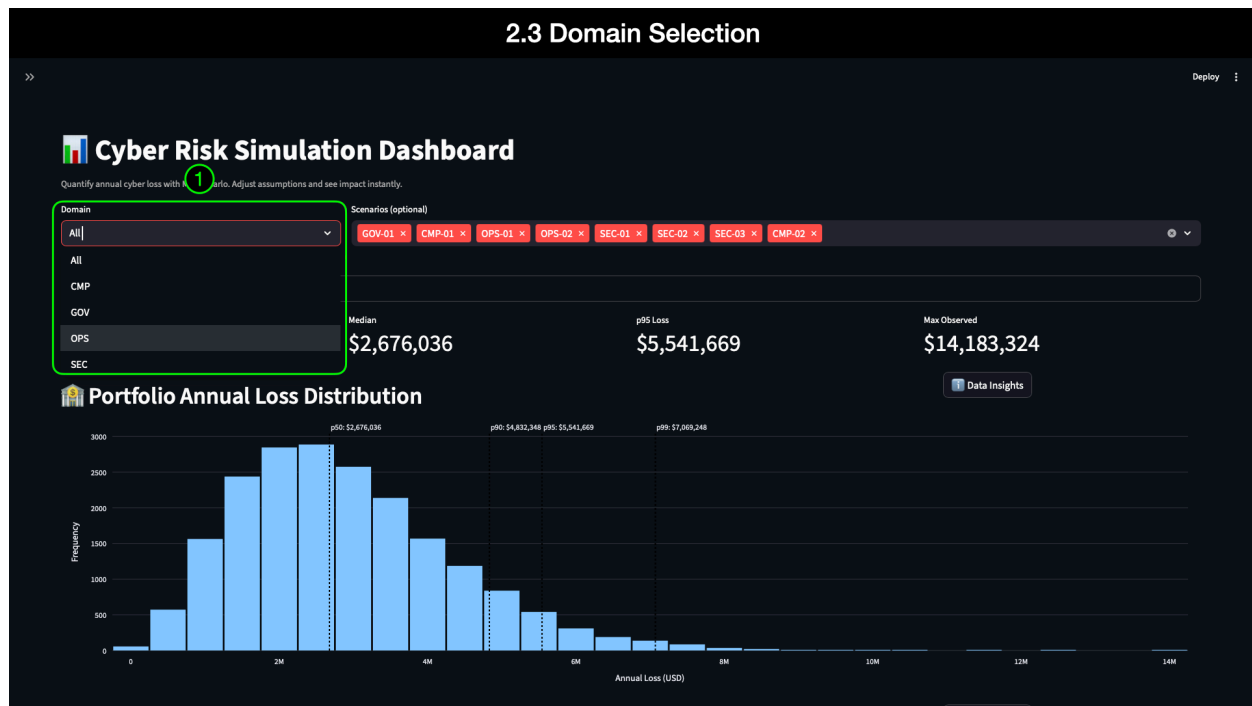
This resource is ideal for readers who want to understand *how* the results shown in the RiskQuant dashboard are computed and validated.

Next, the demonstration will drill deeper by using the **Domain** dropdown to focus on *Operational (OPS)* risks — highlighting how individual threat categories contribute to the overall loss distribution.

2.3 Domain Selection

The **Domain** filter allows users to focus analysis on a specific category of organizational risk within the loaded register. Each domain represents a logical grouping of related risks—whether by functional area, control family, or business process—and helps decision-makers isolate the factors that matter most to their roles.

The default view displays **All** domains, aggregating every scenario in the selected risk register into a single portfolio simulation. Users can refine the analysis by choosing a specific domain to narrow the scope and compare outcomes across organizational areas.



Annotation 1: Domain Menu

The drop-down menu lists the available domains defined in the current register:

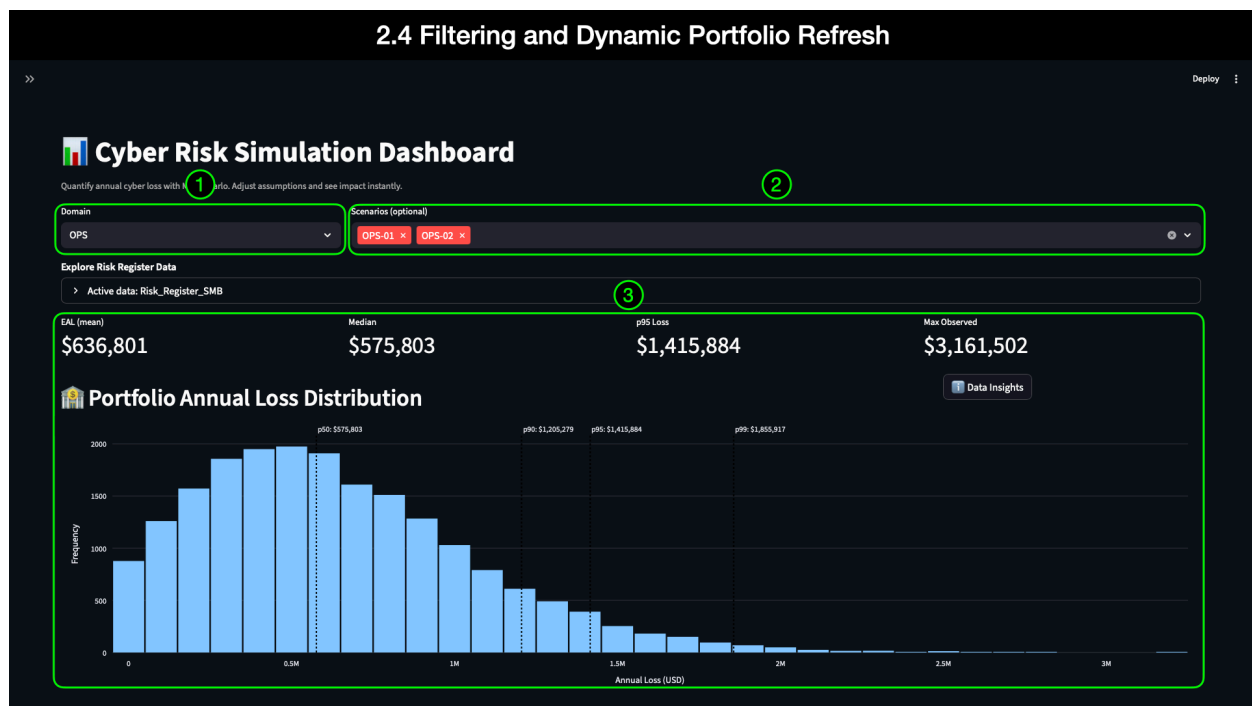
- **All** – Includes every risk scenario across the portfolio (default).
- **CMP** – Compliance and regulatory risks (e.g., HIPAA, PCI DSS, GDPR).
- **GOV** – Governance, policy, and oversight-related risks.
- **OPS** – Operational and service-delivery risks (highlighted in this example).
- **SEC** – Security-specific technical and procedural controls.

Selecting **OPS** in this example filters the simulation and all downstream visualizations to display only operational risk scenarios. SMB owners and analysts can use this filter to focus on how process disruptions, vendor incidents, or service outages influence expected

annual loss and tail exposure, without being distracted by unrelated governance or compliance risks.

2.4 Scenario Filtering and Dynamic Portfolio Refresh

Once the **OPS** domain is selected, the dashboard automatically refreshes to display only the operational risk scenarios within that category. This real-time filtering capability is one of RiskQuant's core design principles—removing friction between user input and analytical insight.



Annotation 1: OPS Domain Selected

The **Domain** drop-down now shows **OPS**, indicating that the simulation scope is limited to operational risks. This framing situates the analysis within the context of day-to-day service continuity, vendor reliability, and system operations—critical areas of exposure for SMBs that rely on third-party IT and cloud providers.

Annotation 2: Scenarios (Optional)

Within the selected domain, the **Scenarios** list dynamically updates to display only those associated with the chosen domain—in this case, **OPS-01** and **OPS-02**. Users can toggle these scenarios individually to isolate specific events (for example, a vendor data breach versus a local system outage) or re-enable both to assess combined operational exposure.

Annotation 3: Updated Portfolio Annual Loss Distribution

With the OPS filter applied, the simulation recalculates the **Expected Annual Loss (EAL)** and related statistics, instantly updating the histogram and summary metrics:

- **EAL (mean):** \$636,801
- **Median:** \$575,803
- **p95 Loss:** \$1,415,884
- **Max Observed:** \$3,161,502

The resulting distribution graph visually shifts to reflect the smaller, domain-specific portfolio. This instant feedback enables analysts and business leaders to understand how isolated domains contribute to total exposure and to explore “what-if” scenarios without repeatedly reloading or manually recomputing results.

By integrating **automatic dashboard refresh** with intuitive selection logic, RiskQuant minimizes the cognitive overhead of tool operation—enabling users to spend less time configuring and more time interpreting results. This design principle reflects RiskQuant’s purpose: empowering data-driven, low-friction decision-making across both technical and non-technical audiences.

Section 3: Interpreting RiskQuant Results

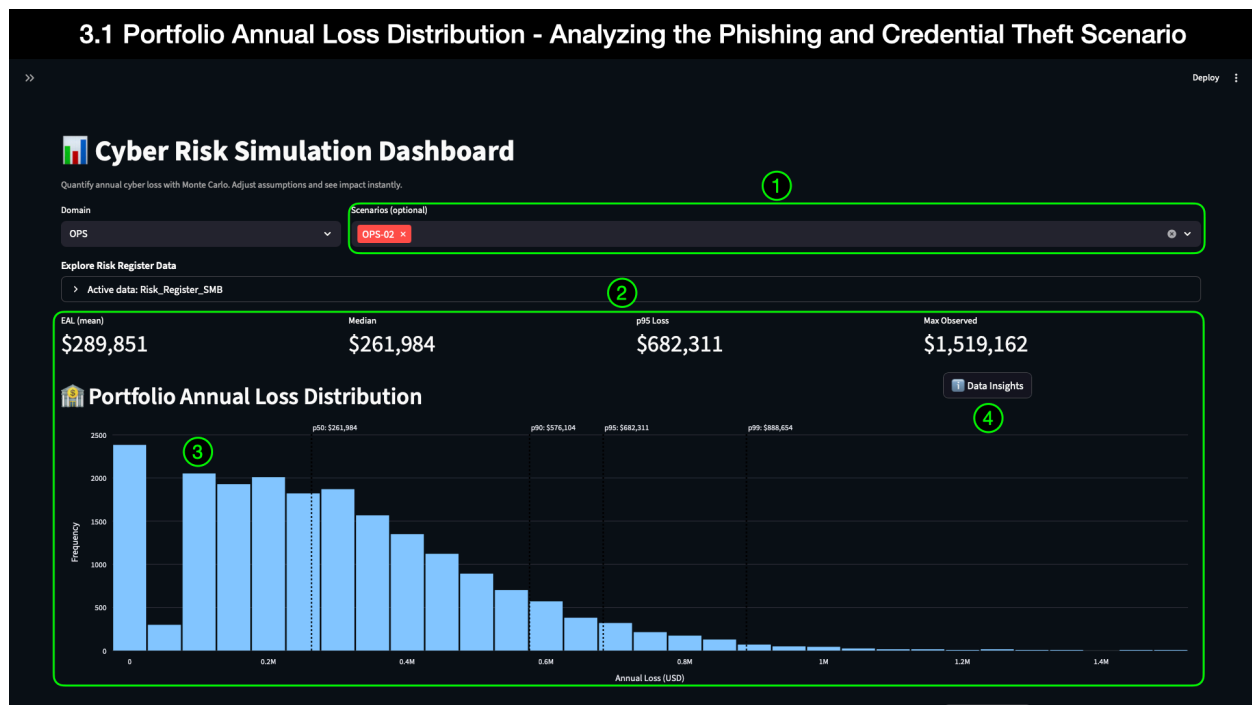
After configuring RiskQuant with the SMB dataset, the simulation focuses on **OPS-02: Phishing and Credential Theft**, a leading threat category for small and medium-sized businesses. Phishing remains the **most common initial attack vector in SMB breaches**, accounting for **nearly 40% of incidents**. At the same time, stolen credentials contribute to **over one-quarter of ransomware and data-exfiltration events** [1][2].

For SMBs, these compromises frequently lead to **ransomware infections, invoice or payroll fraud, and regulatory exposure**. The mean cost of a credential-related breach for small businesses now exceeds **\$2.9 million**, with downtime averaging **23 days** per incident [3].

By simulating thousands of potential outcomes, RiskQuant transforms these raw probabilities into **financially meaningful estimates**—quantifying not only *what could happen*, but *how much it could cost*. The following walkthrough illustrates how each visualization translates complex statistics into **business intelligence** that supports budgeting, insurance justification, and control prioritization.

3.1 Portfolio Annual Loss Distribution — Analyzing the Phishing and Credential Theft Scenario

With the simulation narrowed to the **OPS-02: Phishing and Credential Theft** scenario, RiskQuant's **Portfolio Annual Loss Distribution** provides a statistically grounded view of potential outcomes—from routine incidents to rare, high-impact events. This visualization is crucial for understanding the magnitude and frequency of losses within the SMB threat landscape. The distribution of simulated phishing losses mirrors real-world SMB breach patterns, where most incidents result in low-to-moderate financial impact but rare, severe events exceed \$1 million [1][2][3].



Annotation 1: Scenarios Set to OPS-02

The **Scenarios** bar indicates that **OPS-02** represents *Phishing & Credential Theft* in the SMB Risk Register, mapped from real SMB loss data and industry breach statistics. Each risk ID corresponds to a discrete entry in the register (for example, “OPS-02 Phishing and Credential Theft”) that includes likelihood and loss parameters such as **Lambda_Min/Mode/Max** and **Loss_Min/Mode/Max**.

By isolating OPS-02, the simulation focuses exclusively on this operational threat, generating a distribution of possible annual losses based on the range of frequencies and impacts defined in that row of the risk register.

Annotation 2: Portfolio Annual Loss Distribution Visualization

Demonstrates how the frequency of simulated outcomes translates into an expected loss curve for this specific threat. This histogram represents the frequency distribution of total annual loss values derived from thousands of Monte Carlo trials. It is one of the most widely used visualization methods in quantitative risk analysis because it exposes both **central tendency** (typical outcomes) and **tail behavior** (rare but severe events).

In risk-management practice, this view helps teams visualize **risk appetite** and **tolerance**, determine where most of their exposure lies, and communicate financial risk in a form familiar to executives and insurers.

Annotation 3: Annual Loss Expectancy Calculation and Simulation

Represents the modal loss cluster—an aggregation of partial compromise costs, often resulting from invoice fraud or short business email compromise (BEC) events. Each bar in the histogram represents the number of simulated years that resulted in a given range of total loss values.

RiskQuant calculates **Annual Loss** by multiplying the number of simulated loss events in a year by their corresponding severities, then aggregating these results across all risks in the selected scenario. This approach mirrors the **Annualized Loss Expectancy (ALE)** concept used in quantitative risk assessment, where:

$$\text{ALE} = \text{Single Loss Expectancy (SLE)} \times \text{Annual Rate of Occurrence (ARO)}$$

While traditional ALE produces a single static value, Monte Carlo expands it into a **probabilistic distribution**, showing the full range of possible outcomes rather than a single point estimate.

The visible peaks—particularly the \$100,000 bar—represent common outcomes where smaller phishing events occur, reinforcing that even modest incidents can accumulate significant annual impact.

Annotation 4: Data Insights Button

Provides in-app interpretation of EAL, Median, and p95 to help non-technical users connect simulated values to familiar business terminology. It allows users to access definitions and interpretation tips without leaving the visualization.

We'll explore this feature next, but its inclusion reflects RiskQuant's philosophy of **user-empowered analysis**—embedding documentation, best-practice guidance, and educational content directly into the analytical workflow.

Audience-Focused Insights

- **Business Executives** can interpret the **Expected Annual Loss (EAL)** and **p95** values as tangible indicators of financial exposure. The **p95** figure (\$682K) represents a “worst-case-credible” loss, informing **cyber-insurance coverage** levels, **contingency reserves**, and **budget allocation** for preventive controls.
- **GRC Analysts** and **Risk Managers** can explore the shape of the distribution to assess **risk concentration** and **tail behavior**. The heavy tail and dual peaks indicate that while minor phishing incidents are common, occasional severe compromises can produce disproportionately large losses.

- **Technical and Security Teams** can connect these statistical insights back to control performance—identifying whether investments in **email filtering**, **MFA adoption**, or **employee awareness training** could reduce the probability mass in the higher-loss region.

Simulation-Derived Metrics

- **EAL (mean):** \$289,851 — The average expected loss across all simulated years.
- **Median (P50):** \$261,984 — A “typical” year’s loss, functional for budgeting.
- **p95 Loss:** \$682,311 — A tail-risk benchmark used in insurance and compliance reporting.
- **Max Observed:** \$1,519,162 — The most extreme simulated case, illustrating outlier potential.

Interpreting the Distribution

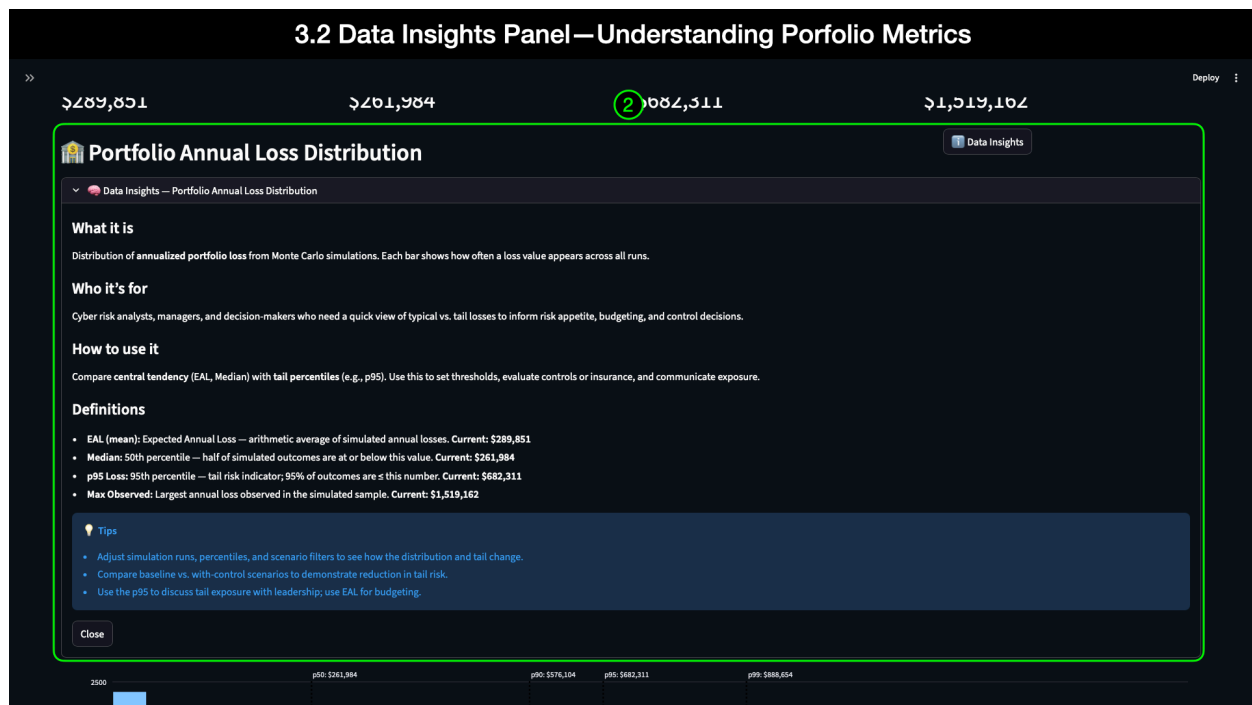
This distribution reveals that **phishing and credential theft losses** for SMBs often cluster around lower-to-mid-range annual impacts, punctuated by infrequent but severe outliers. The dual-peaked pattern—one near **\$0–\$100K**, another around **\$250K–\$500K**—mirrors real-world bifurcation between **prevented attempts** (no loss) and **successful compromises** leading to partial or complete data exposure.

The **p95 value (\$682K)** represents the *tail risk*—a plausible worst case reflecting a successful compromise followed by ransomware, data exfiltration, and business-interruption costs.

The histogram visually represents **the likelihood and severity of SMB-scale phishing incidents**, providing analysts with a defensible basis to evaluate insurance coverage thresholds or justify investments in MFA and user training.

3.2 Data Insights Panel — Understanding Portfolio Metrics

The **Data Insights Panel** is one of RiskQuant’s most distinctive usability features—a built-in, context-aware guide designed to educate, inform, and empower users as they explore the dashboard.



Annotation 1 – Data Insights Panel (Full View):

Opening the panel reveals structured sections—**What it is**, **Who it's for**, **How to use it**, **Definitions**, and **Tips**—that explain the purpose and interpretation of each visualization. The content is concise yet informative, offering just enough context for users of varying technical backgrounds to engage with the data confidently.

This feature functions as **in-product documentation**, bridging the gap between raw analytics and human understanding. It allows RiskQuant to serve a **diverse audience**—from business executives to technical analysts—without requiring them to consult external manuals or training materials.

By embedding interpretive guidance directly into the interface, RiskQuant:

- **Removes friction** for new users, reducing the learning curve and enabling instant engagement.
- **Educates continuously**, reinforcing best practices in risk quantification and interpretation with each use.
- **Promotes consistency**, ensuring that decision-makers across functions uniformly interpret visualizations.
- **Supports autonomy**, allowing users to learn at their own pace and interactively explore results without breaking analytical flow.

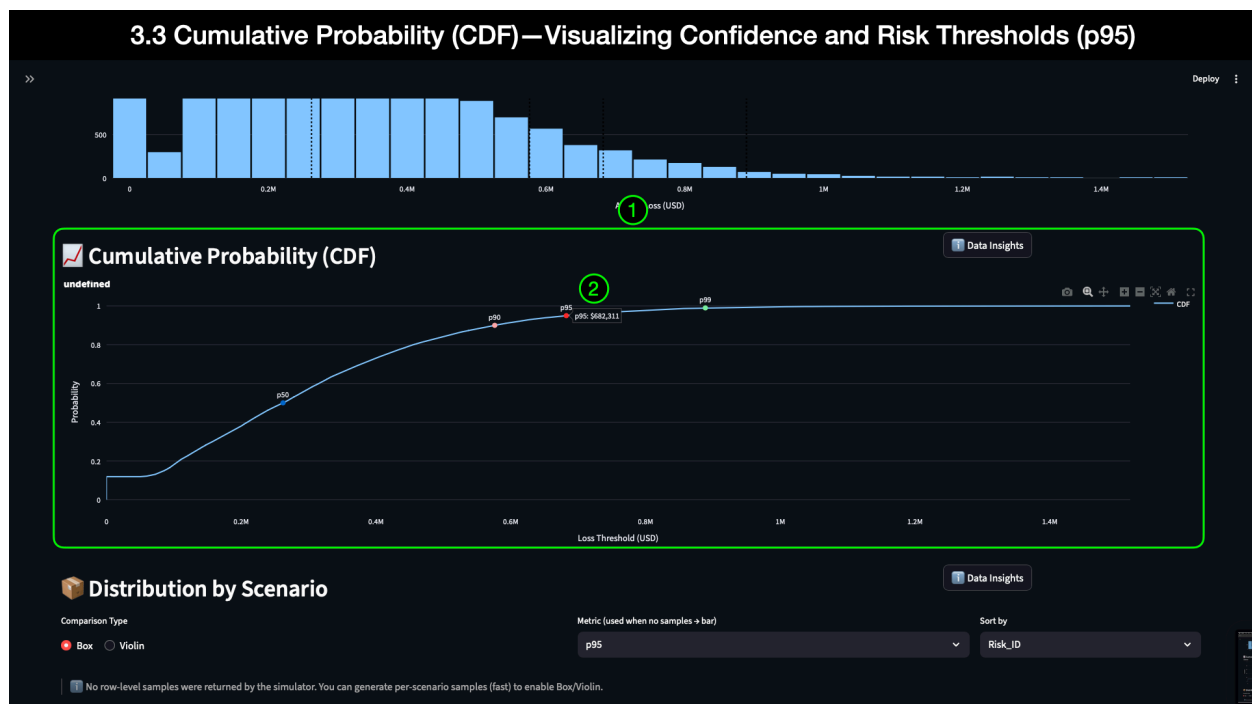
For new analysts or business leaders unfamiliar with Monte Carlo methods, this panel transforms RiskQuant from a technical simulation tool into an intuitive decision-support platform—one that not only visualizes data but also teaches *how to think with it*.

3.3 Cumulative Probability (CDF) – Visualizing Confidence and Risk Thresholds

The **Cumulative Distribution Function (CDF)** visualization complements the histogram by showing the *likelihood that the total annual loss will not exceed a given threshold*.

Instead of asking "How often does this loss occur?", the CDF answers "What is the probability that losses stay below this amount?"—a crucial view for setting budgets, defining risk appetite, and quantifying confidence in loss forecasts.

Phishing and credential theft at SMBs exhibit both **high frequency and wide impact variability**. The *Verizon DBIR* notes that **83% of SMB breaches involve human factors**, and credential misuse remains a top-five root cause [1][2]. The CDF curve quantifies this uncertainty: while half of simulated losses (p50) stay below **\$250K**, there is still a **5% probability of exceeding \$680K**, signaling substantial tail risk even for smaller organizations.



Annotation 1: Understanding the CDF

The **Cumulative Distribution Function** (CDF) defines the probability that a loss is less than or equal to a given value:

$$F(x) = P(X \leq x)$$

Where $F(x)$ is the probability that the simulated annual loss X is less than or equal to a given threshold x .

Each point on the curve represents the cumulative proportion of all Monte Carlo samples below that value, turning a raw histogram into a *probability-of-not-exceeding* chart.

This transformation enables risk stakeholders to select thresholds and instantly view the associated confidence levels easily.

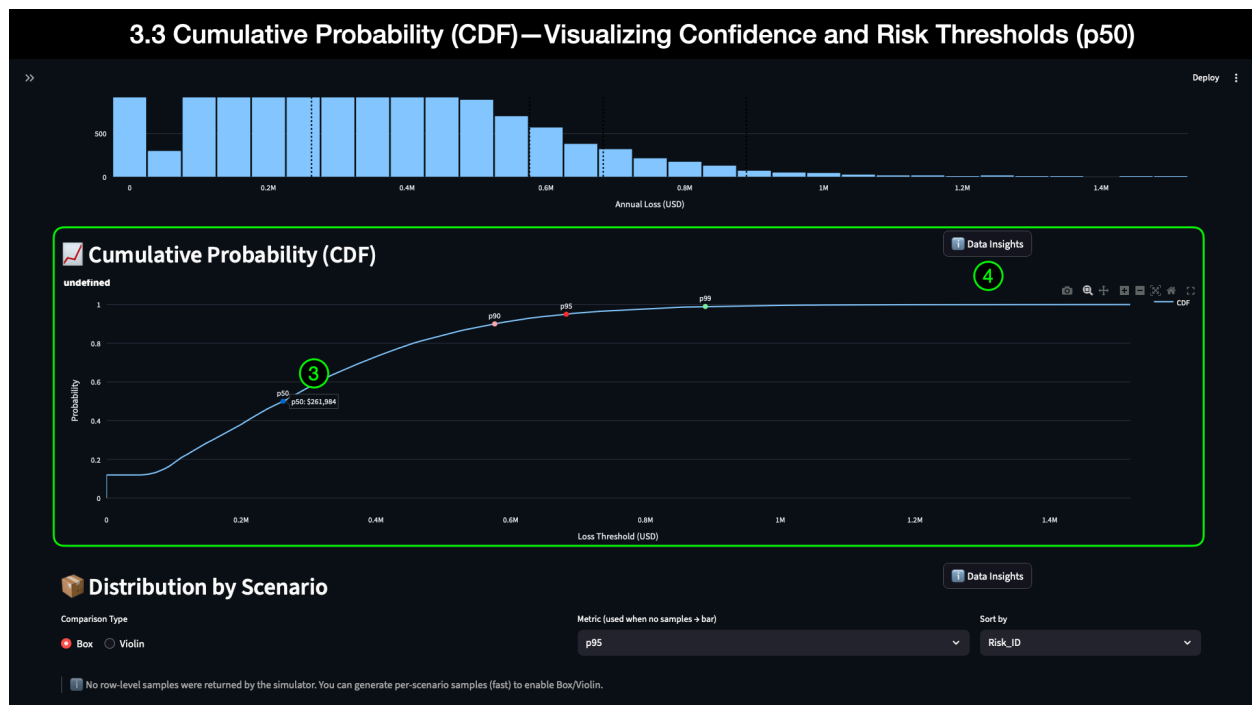
Annotation 2 – p95 Value on the Curve

Hovering over the **p95 marker** shows the point where *95% of simulated outcomes fall below \$682 311*.

This point marks a critical decision moment for executives and insurers, quantifying a "credible worst-case year" and answering questions such as,

“What loss magnitude are we 95% confident we will not exceed?”

It also serves as an anchor for resilience and coverage planning.



Annotation 3: p50 Value on the Curve

In the second screenshot, hovering over **p50** displays $P(\text{Loss} \leq \$250,011) = 48\%$, showing the midpoint of the distribution.

For planners and analysts, this value represents the "most typical" year—one that informs average-case budgeting, expected loss estimates, and comparisons between controls or scenarios.

Used together, p50 and p95 give leadership both the **expected** and **adverse** perspectives needed for balanced decision-making.

Annotation 4 – Data Insights Button

The **Data Insights** button, located on the right side of the chart, provides contextual explanations and usage guidance.

Like the other panels, it ensures consistency in how teams interpret statistical data across the organization.

In the next section, we'll explore this panel to understand how RiskQuant teaches users to confidently interpret the CDF—turning statistical literacy into operational insight.

Audience-Focused Insights

- **Business Executives** can use the CDF to establish *confidence-based thresholds*. For example, if leadership is comfortable with a 95% chance that annual losses stay below \$682K, that becomes a defensible *risk-tolerance boundary* or *insurance coverage level*.
- **GRC Analysts** leverage the CDF to align organizational risk appetite with objective data, identifying the percentage of simulated years that exceed existing control budgets or policy limits.
- **Security and Operations Teams** can use the slope of the curve to evaluate *control effectiveness*: a steeper curve near lower losses implies tighter, more predictable outcomes. In comparison, a shallower curve suggests variability and control gaps.

Simulation-Derived Metrics

- **p95:** \$682 311 — A 95% probability that annual losses will be less than this amount (the “bad-but-plausible” year).
- **p50 (Median):** \$250 011 — A 50% probability that annual losses will be less than this amount (a “typical” year).
- **Confidence Span (p95–p50):** ~\$432 000 — The range between typical and tail-risk outcomes, quantifying uncertainty.

Interpreting the Visualization

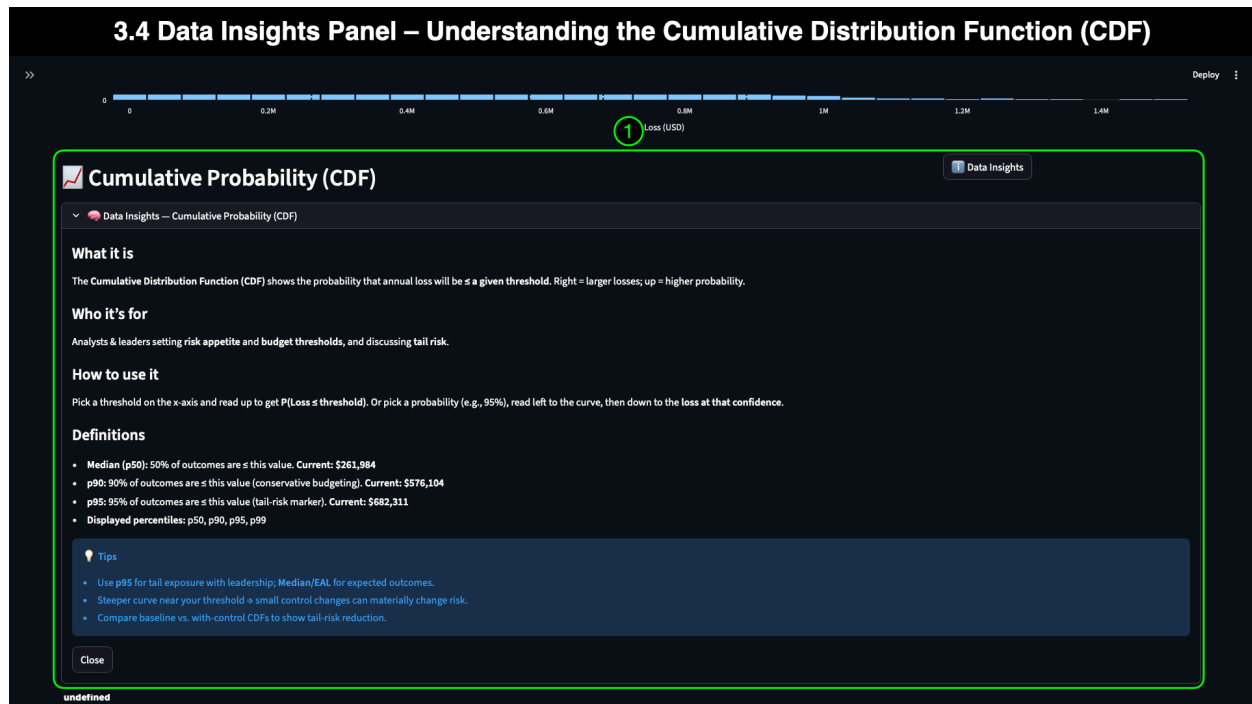
The ascending CDF curve illustrates how the cumulative probability increases as losses rise. Its steep rise below the \$300K mark indicates that **most phishing events result in modest direct losses**. In comparison, the gradual tail beyond \$500K highlights **the small but real risk of catastrophic breach escalation**.

For executives, the **p95 marker** is a proxy for “**budgeting to the 95% confidence level**”, ensuring financial reserves or insurance coverage for 19 out of 20 likely scenarios. For analysts, the **p50 and p95 spread** quantifies control uncertainty—how effectively MFA, phishing training, or email filtering narrows the risk curve.

3.4 Data Insights Panel – Understanding the Cumulative Distribution Function (CDF)

The **Data Insights Panel** for the Cumulative Probability visualization provides targeted guidance for interpreting probabilistic outcomes. It helps users bridge the gap between

statistics and *strategic action*—clarifying what percentile thresholds mean in practical, business terms.



Annotation 1: Cumulative Probability (CDF) Data Insights

Within this panel, RiskQuant outlines:

- **What it is:** Explains that the curve shows the probability that annual losses will remain below a given value.
- **Who it's for:** Identifies executives, analysts, and risk officers who define *risk tolerance* and *budget limits*.
- **How to use it:** Demonstrates how to read probabilities and thresholds directly from the curve—whether to find the confidence level for a loss limit or determine what loss corresponds to a specific percentile (e.g., p95).
- **Definitions:** Reinforces key terms, such as *median*, *percentile*, and *probability of non-exceedance*, to ensure a shared understanding across teams.
- **Tips:** Suggests how to apply CDF insights in practice—for example, using the p95 for insurance or reserve setting, and the p50 for budgetary planning.

By presenting these interpretive anchors directly beside the visualization, the panel transforms a statistical graph into a decision-support tool.

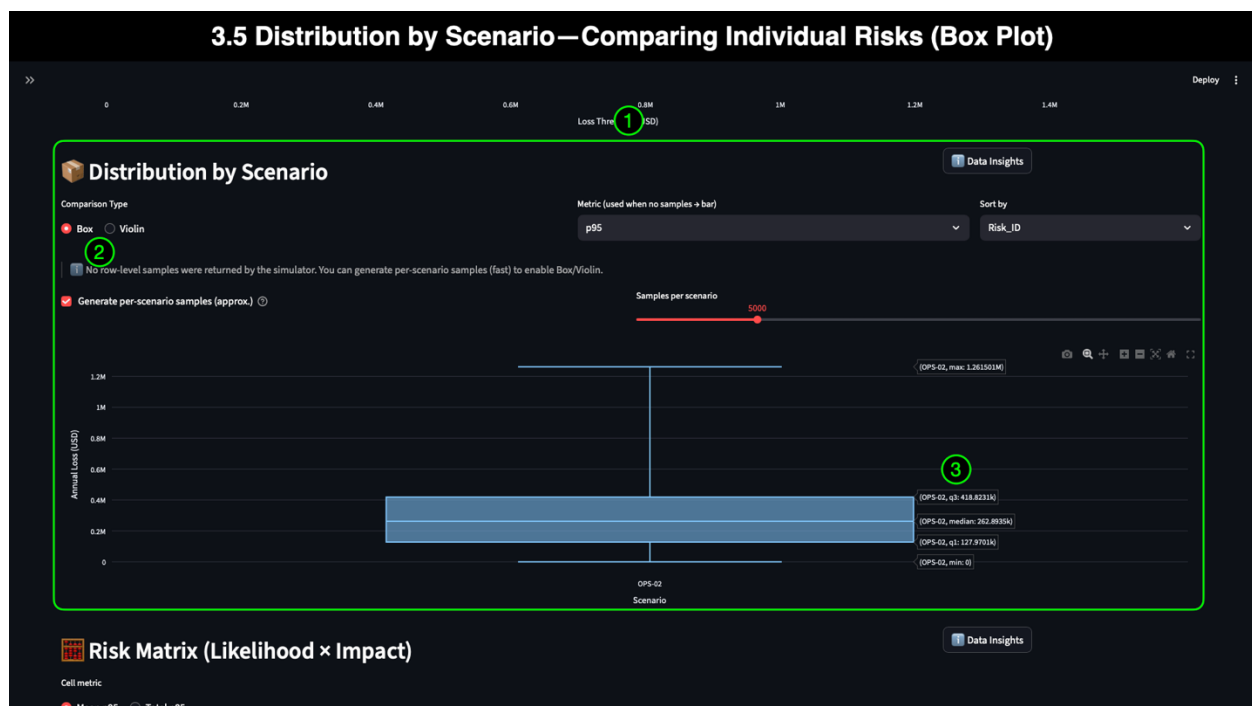
It ensures that all stakeholders—technical or not—can read the same curve and reach the same conclusion about *how confident the organization can be in avoiding certain loss levels*.

3.5 Distribution by Scenario – Comparing Individual Risks

Although this simulation focuses on **OPS-02: Phishing and Credential Theft**, the Distribution by Scenario visualization illustrates how **individual risks behave as distinct statistical entities**.

In the Box and Violin views, the **quartiles, median line, and tails** represent variability across repeated simulations. For phishing events, the violin shape—a flattened bell with an extended upper tail—reveals that while **most losses concentrate around \$250K–\$300K**, rare but severe cases can exceed **\$1 million**.

This pattern reflects real-world SMB outcomes, where a single credential compromise can lead to ransomware, data breach costs, and reputational damage. The Violin plot’s “width” visually encodes **uncertainty and potential volatility**, helping risk managers prioritize mitigations that reduce tail spread (e.g., stronger identity protection). The Violin plot’s elongated tail reflects rare, severe compromise events that escalate into ransomware or data exfiltration, consistent with SMB breach behavior reported by ENISA and Datto [4][3].



Annotation 1: Distribution Visualization (p95 Displayed)

The chart displays scenario-level distributions, with **p95** chosen as the key comparison metric.

Each box summarizes thousands of Monte Carlo samples for a single risk (in this case, *OPS-02 Phishing and Credential Theft*).

Behind the scenes, RiskQuant groups all simulated losses for that scenario, ranks them, and extracts the percentiles—mean, median, p90, p95—to quantify uncertainty.

Users can switch metrics at any time (e.g., from p95 to median or mean) to focus on different analytical perspectives.

Annotation 2: Comparison Type: Box

The **Box plot** displays the interquartile range (Q1–Q3), the **median line**, and **whiskers** representing the lower and upper extremes.

Mathematically, each box uses the following values:

$$Q_1 = 25^{\text{th}} \text{ percentile}, Q_3 = 75^{\text{th}} \text{ percentile}, \text{IQR} = Q_3 - Q_1$$

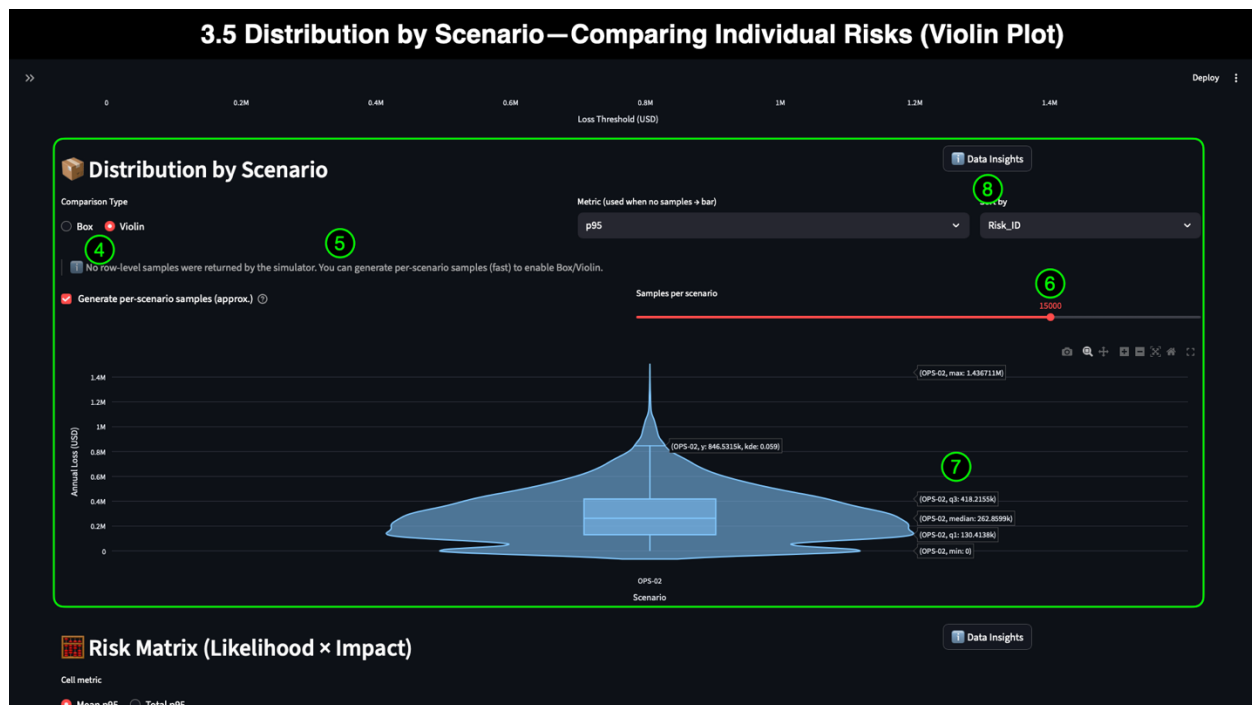
The plot shows outliers beyond $1.5 \times \text{IQR}$ as individual points, highlighting rare but significant deviations.

Box plots are ideal for highlighting **consistency and skew**—a compact view of both risk magnitude and predictability.

Annotation 3: Hover Card (OPS-02)

Hovering reveals contextual details—**Category: OPS, Risk_ID: OPS-02, p95: \$682 311 k**—linking visual data directly to its source entry in the risk register.

This interactivity enables analysts to validate assumptions and trace quantitative outputs back to their qualitative origins, thereby maintaining transparency throughout the analysis.



The **Violin plot** extends the box concept by displaying the full *probability density* of simulated outcomes, showing not just quartiles but also the *shape* of the loss distribution itself.

Its symmetrical form resembles a pair of open high-hat cymbals, where width indicates how frequently a given loss value occurs.

Violin plots excel at showing **bimodal** or **heavy-tailed** risks that box plots may obscure.

Annotation 4: Comparison Type: Violin

Selecting **Violin** replaces discrete quartiles with a smoothed kernel density estimate (KDE), calculated by evaluating the distribution's probability density function:

$$\hat{f}(x) = \frac{1}{nh} \sum_{i=1}^n K\left(\frac{x - x_i}{h}\right)$$

Where K is the kernel function, and h is the bandwidth parameter.

This approach visualizes the likelihood of specific loss magnitudes—wide regions represent more probable outcomes, while narrow tips denote rare extremes.

Annotation 5: Generate Per-Scenario Samples Toggle

When this toggle is activated, RiskQuant locally generates samples for each scenario using the parameters from the risk register.

This value becomes especially useful when the initial simulation does not return per-scenario detail for performance reasons.

By sampling locally, users can explore the shape of each scenario without rerunning the entire portfolio simulation, making it ideal for quick "what-if" exploration.

Annotation 6: Samples per Scenario (15,000)

This control determines the number of draws the local sampling function performs per risk.

Higher values (e.g., greater than 15,000) yield smoother, more stable shapes, but increase computation time. In comparison, lower values make distributions coarser but faster to visualize.

The default of **5,000 samples** strikes a balance between visual clarity and responsiveness.

Annotation 7: Violin Graph Shape

The hover details—**OPS-02**, *y: \$419 394 k, Q1: \$127 970 k, Median: \$262 894 k, Q3: \$418 823 k, Min: \$0*—illustrate the scenario's loss profile.

The **flattened bell** shape suggests that most outcomes cluster around moderate losses, with a diminishing frequency toward higher tails—typical for SMB-scale phishing risks with limited systemic exposure.

Annotation 8: Data Insights Button

The familiar **Data Insights** button is also available.

As before, it provides embedded guidance on interpreting scenario-level distributions.

We'll explore this specific panel next to see how it supports comparative analysis across multiple risks.

Audience-Focused Insights

- **Executives and Decision-Makers** can visually rank scenarios by exposure and volatility, quickly spotting which operational or compliance domains warrant attention.

- **GRC Analysts** use this chart to assess dispersion and skew across multiple risks, understanding not only which risks are most significant but also which are *least predictable*.
- **Technical Security Teams** can connect the variability in distributions to control maturity—wider distributions often correspond to inconsistent defenses or incomplete implementations.

Simulation-Derived Metrics

- **p95:** \$682,311 — The 95th-percentile annual loss for the OPS-02 scenario.
- **Median (P50):** \$262,894 — The “typical” year’s outcome for this risk.
- **IQR (Q3 – Q1):** ~\$290,853 — The range capturing the central 50 % of all simulated losses.
- **Min/Max:** \$0 – \$1,519,162 — The total observed range of possible outcomes across all 5,000 local samples.

Interpreting the Visualization

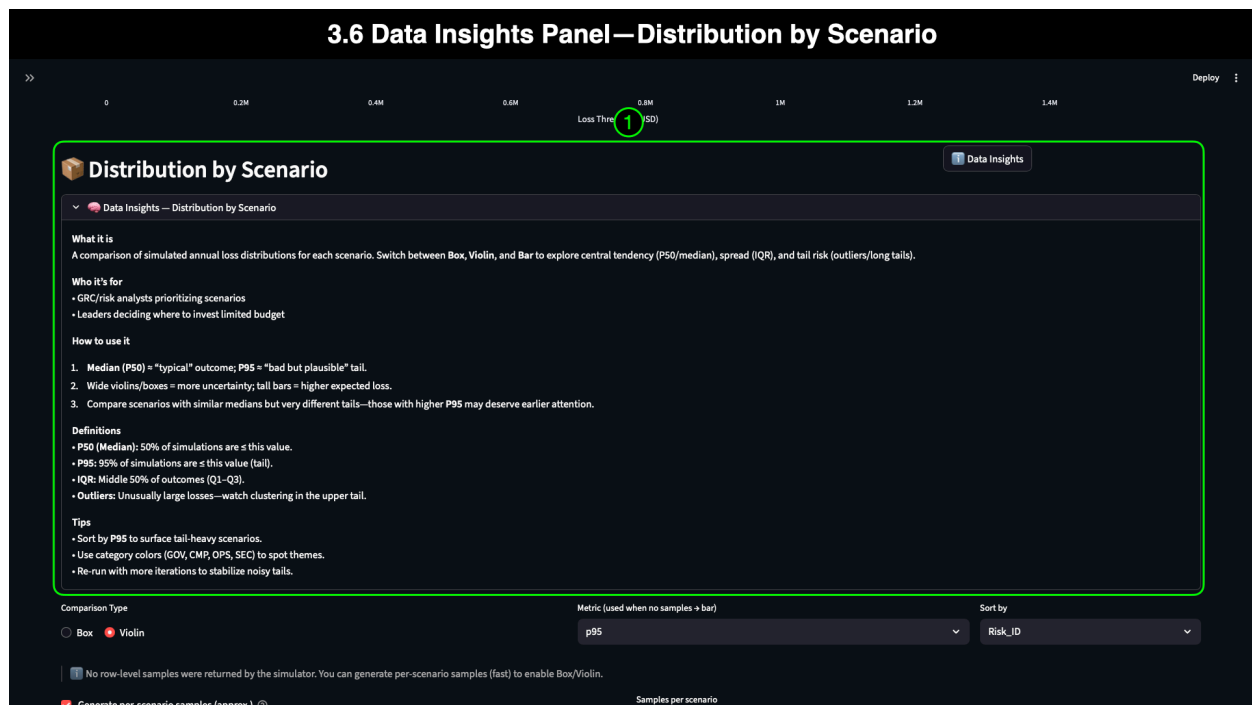
This visualization shifts focus from the entire organization to *individual risk performance*.

Each Box or Violin plot represents the annual loss distribution of a separate scenario, allowing for a side-by-side comparison of its **central tendency (median)**, **spread (IQR)**, and **tail behavior (outliers)**.

Selecting different comparison types—**Box** or **Violin**—changes how the underlying samples appear, offering complementary views of variability and concentration.

3.6 Data Insights Panel – Distribution by Scenario

The **Data Insights Panel** for the *Distribution by Scenario* view expands on the comparative purpose of this visualization—helping users interpret what differences in shape, width, and spread truly mean in risk-management terms.



Annotation 1: Distribution by Scenario – Data Insights Panel

Inside this panel, the guidance focuses on scenario-level interpretation:

- **What it is:** Clarifies that each box or violin represents thousands of simulated annual loss outcomes for a single scenario, enabling side-by-side comparison of variability and tail severity.
- **Who it's for:** Targets **analysts and risk managers** who must prioritize among competing threats and **leaders** who decide where to allocate mitigation budgets.
- **How to use it:** Explains how to switch between *Box* and *Violin* modes to reveal different statistical perspectives—using *Box* for clarity of quartiles and *Violin* for understanding distribution shape and density.
- **Definitions:** Reinforces core percentile terms (median, p95, interquartile range) and connects them to decision thresholds such as *risk appetite* and *acceptable loss variance*.
- **Tips:** Advises users to sort scenarios by p95 to surface high-impact, tail-heavy risks first; to monitor changes in spread after control improvements; and to use consistent sample sizes when comparing scenarios.

Where the Portfolio-level charts quantify *overall exposure*, this panel provides a *comparative lens*—showing how individual risks differ not only in size but also in **stability**.

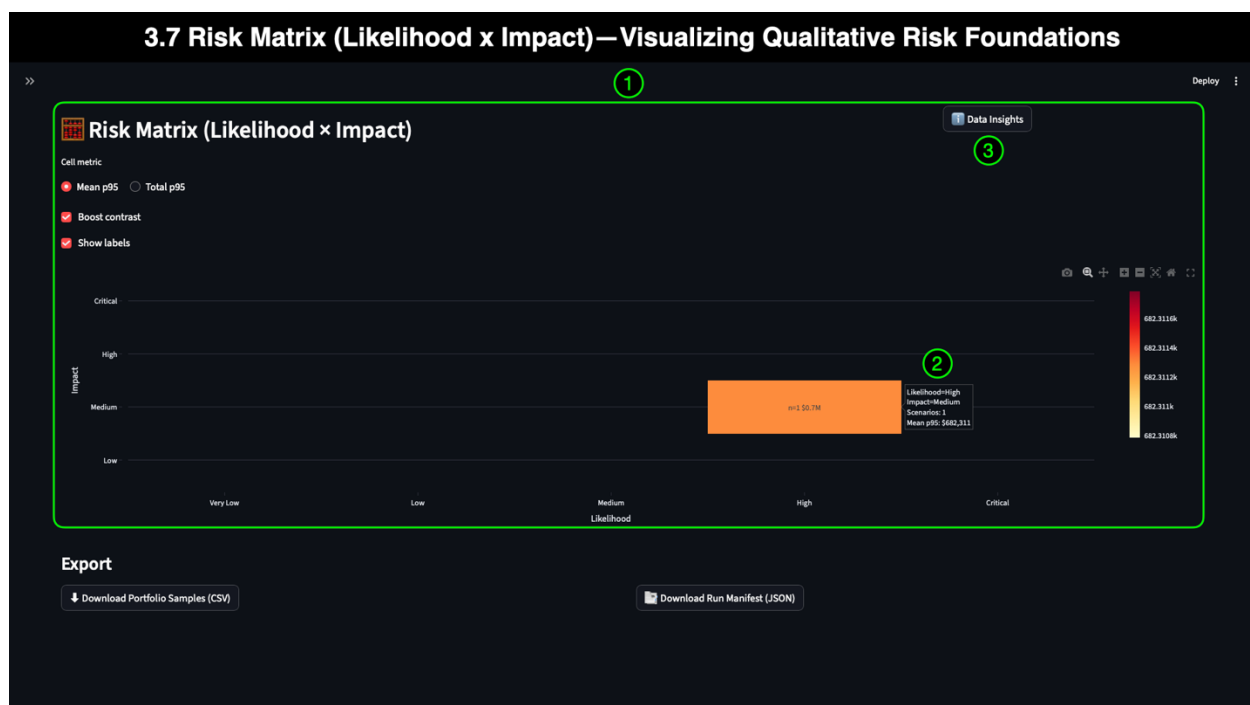
In doing so, it turns Monte Carlo results into a visual triage tool: teams can immediately see which scenarios are volatile, which are well-controlled, and which demand executive attention.

3.7 Risk Matrix (Likelihood × Impact) – Visualizing Qualitative Risk Foundations

The Risk Matrix visualizes the qualitative underpinnings of **OPS-02: Phishing and Credential Theft**, before quantification. In frameworks like **NIST SP 800-53**, **NIST SP 800-37 (RMF)**, and **ISO 27005**, analysts assign likelihood and impact categories using expert judgment—often subjective but necessary when data are limited.

Frameworks such as *NIST SP 800-53* [5], *NIST SP 800-37* [6], and *ISO/IEC 27005* [7] guide analysts in evaluating risk qualitatively, while ENISA reports that **over 90% of successful breaches begin with phishing** [4][1].

This baseline qualitative cell becomes the **input that RiskQuant later converts into quantitative loss projections** through Monte Carlo simulation.



Annotation 1: Risk Matrix Visualization

The matrix is constructed directly from the **Likelihood** and **Impact** fields in the risk register, which contain qualitative values derived from expert assessments or compliance frameworks.

During simulation, these categorical labels guide the parameter mapping process, converting them into the quantitative λ (frequency) and loss ranges (min/mode/max) used by the Monte Carlo engine.

The resulting visualization reflects both perspectives: the **qualitative baseline** and the **quantitative overlay**, harmonizing intuition and evidence.

Annotation 2: Medium Impact × High Likelihood Cell

This cell, colored **dark orange** and labeled **n = 1 \$0.7 M**, corresponds to the *OPS-02 Phishing and Credential Theft* scenario.

Its hue and annotation communicate at a glance how many risks share this profile and the magnitude of their collective exposure.

The visualization uses the mean p95 loss to color cells, ensuring the scale remains intuitive—deeper tones mean higher expected tail losses.

Audience-Focused Insights

- **Executives and Managers:** gain a quick, intuitive snapshot of where risks appear most concerning, even without deep statistical analysis. It's a familiar visualization that communicates urgency and priority at a glance.
- **GRC and Risk Analysts** can use the matrix to verify that qualitative judgments (e.g., “High Impact” and “Medium Likelihood”) align with or diverge from Monte Carlo outcomes, highlighting where perception and probability differ.
- **Compliance and Audit Teams:** see how qualitative assessments map to standardized control frameworks, ensuring traceability and governance alignment.

Simulation-Derived Metrics

- **Mean p95 per cell:** \$0.7 M — represents the average tail loss of all scenarios grouped under that cell's likelihood/impact combination.
- **n (count):** 1 — indicates a single scenario within that qualitative cell (here, *OPS-02 Phishing and Credential Theft*).
- **p95 Sum:** equal to the total estimated 95th percentile loss across all scenarios in that cell.

- The model calculates these values by aggregating Monte Carlo results using the qualitative labels (“Low,” “Medium,” “High,” “Critical”) defined in the risk register.

Interpreting the Visualization

The Risk Matrix serves as both a **reference and a validation tool**. It demonstrates how analysts’ qualitative judgments are translated into quantitative reality once simulated.

Each cell in the grid combines all scenarios sharing the same Likelihood and Impact levels.

Color intensity (from light yellow to deep red) corresponds to the mean or total **p95 loss**, giving an at-a-glance view of where simulated tail exposure is most significant.

The highlighted **Medium Impact / High Likelihood** cell, valued at approximately **\$0.7 million**, indicates the prevalence of phishing, with moderate per-event severity, for SMBs. This context explains why **frequency-reduction controls**—such as training, MFA, and email filtering—deliver disproportionate ROI compared to heavy investment in incident response.

Together, the matrix and simulation outputs create a bridge from *intuition* (“phishing is common”) to *evidence* (“our expected annual loss is ~\$290K, with a 5% chance of exceeding \$680K”).

By combining subjective qualitative data with objective simulated loss figures, RiskQuant visualizes how traditional frameworks (such as NIST SP 800-53 and ISO 27005) serve as the **input layer** for deeper statistical modeling—transforming impressions into evidence for action.

Annotation 3: Data Insights Button

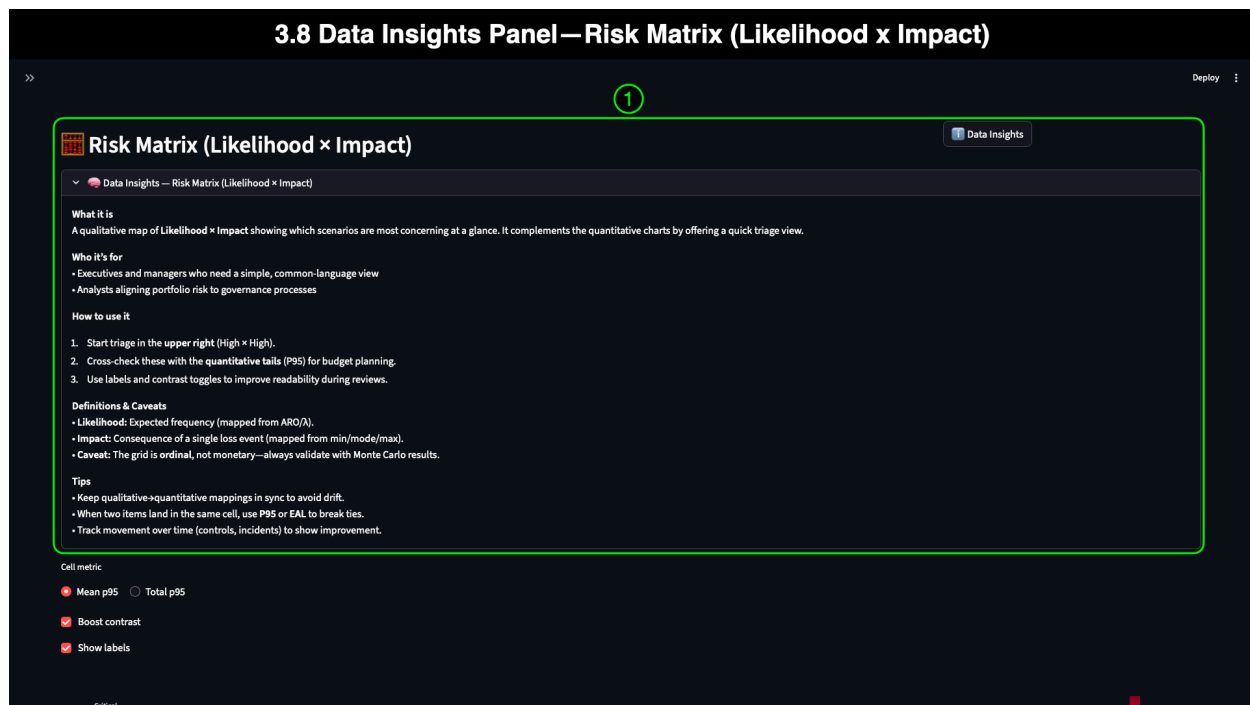
As with previous visualizations, the **Data Insights** button provides in-dashboard documentation and guidance for interpreting the data.

At this stage, users are familiar with its function as an embedded learning aid, so we simply note its presence here.

3.8 Data Insights Panel – Risk Matrix (Likelihood × Impact)

The **Data Insights Panel** for the Risk Matrix provides interpretive context for one of the most familiar tools in risk management.

Its guidance helps users connect the **qualitative judgments** that populate a typical risk register with the **quantitative outputs** that RiskQuant produces through simulation.



Annotation 1: Risk Matrix (Likelihood x Impact) – Data Insights

Within the panel, users will find:

- **What it is:** Describes the Risk Matrix as a qualitative map of **Likelihood × Impact**, used to triage risks based on analyst assessment before simulation.
- **Who it's for:** Highlights its value for **executives**, **risk managers**, and **analysts** who need a quick visual of relative priority or to brief stakeholders without deep statistical detail.
- **How to use it:** Explains how to interpret color intensity as mean or total p95 loss and how to focus review on the upper-right (High × High) quadrant where material risks concentrate.
- **Definitions & Caveats:** Clarifies that “Likelihood” and “Impact” are ordinal—not monetary—values and should be validated against simulation outputs for consistency.
- **Tips:** Recommends monitoring movement within the matrix over time as controls improve or incident frequency changes—using those shifts to show progress in governance and resilience initiatives.

Where the previous visualizations expressed simulated outcomes numerically, this panel reminds users that every quantitative model begins with **expert judgment**.

By keeping qualitative and quantitative views side by side, RiskQuant encourages balanced risk management—anchored in both analytical evidence and human expertise.

Section 4: Exporting and Sharing Simulation Results

For SMBs confronting phishing and credential compromise, the **CSV and JSON exports** enable downstream integration into **risk registers, audit records, and insurance assessments**. RiskQuant's export features reinforce compliance practices outlined in *NIST SP 800-37* [6] and *ISO/IEC 27005* [7], ensuring simulation reproducibility and audit-ready traceability.

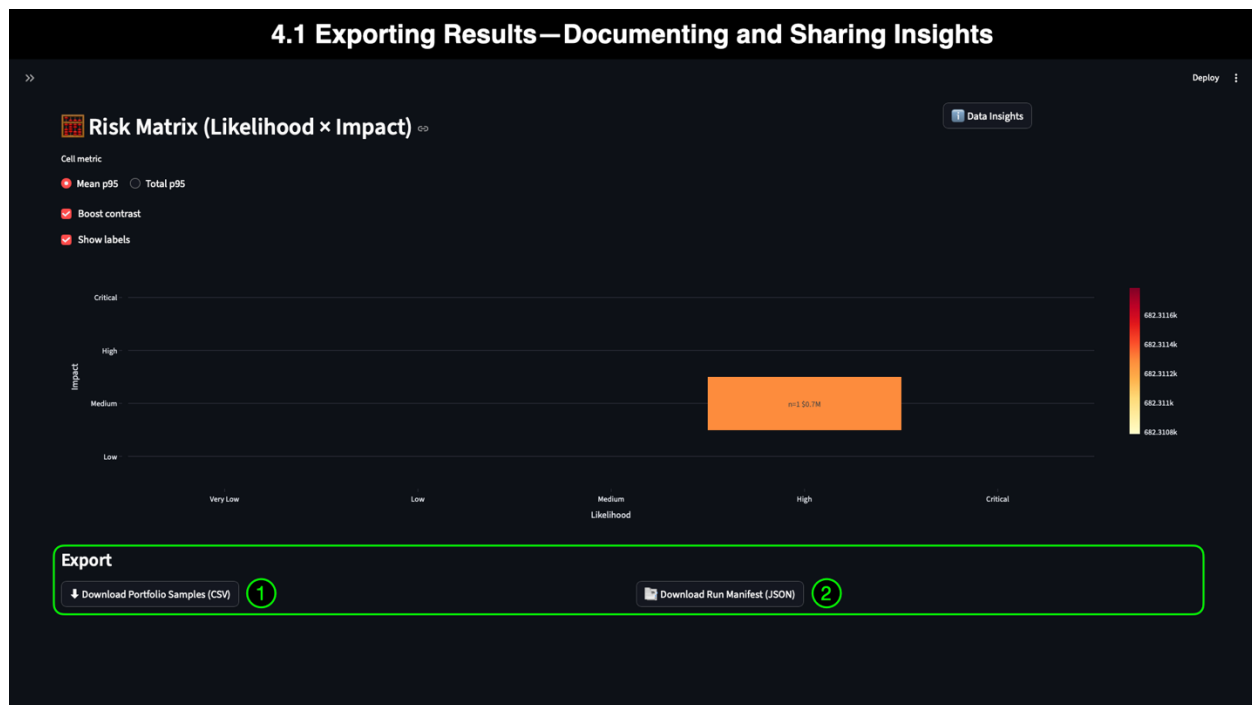
- **CSV (Portfolio Samples):** Contains each simulated annual loss outcome. Analysts can import it into Excel, Power BI, or Python notebooks to perform **trend analysis**, validate **policy effectiveness**, or compare against **cyber-insurance deductible thresholds**.
- **JSON (Run Manifest):** Captures metadata (simulation seed, n-runs, filters, metrics) to ensure **reproducibility**, which is critical for compliance frameworks like **NIST RMF Step 6 (Monitor)** or **ISO 27001:2022 § 10.2, Continual Improvement**.
- In a phishing-focused SMB context, these exports serve as **digital evidence** to support tabletop exercises, regulatory reporting, and renewal justification for cyber-insurance policies.

RiskQuant's export options—**Portfolio Samples (CSV)** and **Run Manifest (JSON)**—represent the final stage of the simulation lifecycle: moving from *interactive insight* to *institutional knowledge*.

4.1 Exporting Results – Documenting and Sharing Insights

The **Export** section at the bottom of the RiskQuant dashboard transforms analytical work into actionable records.

After completing a simulation, users can download two key files: a **Portfolio Samples (CSV)** file and a **Run Manifest (JSON) file**. Together, these outputs ensure that teams can **reproduce, audit, and integrate** every analytical run into broader GRC processes.



Annotation 1: Export: Download Portfolio Samples (CSV)

This file contains the **raw Monte Carlo simulation data, including** every sampled annual loss value generated during the run.

If the simulation included 20,000 trials, the CSV includes all 20,000 outcomes, providing a transparent view of the statistical foundation behind the dashboard's summaries.

Uses in Practice:

- Enables **independent validation** of RiskQuant outputs by data scientists or auditors.
- Facilitates deeper statistical analysis or visualization in tools such as Python, R, or Excel.
- Supports **evidence-based compliance reporting**, showing exactly how risk exposure was modeled and measured.
- Can be archived as part of **risk register documentation**, aligning with governance frameworks that require traceability in risk quantification methods.

The CSV format ensures portability and compatibility with virtually any analysis platform—making RiskQuant’s data both transparent and reusable across teams.

Annotation 2: Export: Download Run Manifest (JSON)

The **Run Manifest** is the structured metadata record of the simulation. It captures configuration parameters (number of simulations, random seed, percentiles, and selected risk register), filters, and key portfolio statistics such as EAL, median, and p95.

Uses in Practice:

- Serves as a **digital fingerprint** of the simulation, preserving the exact settings used for reproducibility.
- Provides **audit-ready evidence** for frameworks that require model governance and repeatable testing methodologies.
- Enables **version control** and historical comparison, allowing analysts to track how risk posture changes as controls evolve or new data becomes available.
- This capability supports **data provenance** within GRC tooling, confirming that decisions rely on consistent, properly documented assumptions.

Together, these files transition RiskQuant from a visual analytics platform to a **quantitative record-keeping tool**, supporting the “assess,” “monitor,” and “report” phases of the risk management lifecycle.

Audience-Focused Insights

- **GRC Analysts and Risk Managers:** can retain simulation results for longitudinal studies, model tuning, and risk-trend reporting.
- **Auditors and Compliance Teams:** Gain a traceable record of risk quantification activities that support documentation requirements for frameworks such as NIST RMF, ISO 27001, and SOC 2.
- **Executives and Decision-Makers:** can share tangible data behind risk decisions—turning simulated insights into budget justifications or board-level summaries.

Interpreting the Outputs

Each export file serves a unique but complementary function within the risk management lifecycle:

Section 5: Translating Insight into Action

Throughout this demonstration, we've explored how RiskQuant transforms the complex world of cyber risk into visual, data-driven intelligence.

By simulating thousands of potential outcomes and visualizing their impacts, the platform enables each member of a cybersecurity or GRC team to transition from **intuition to evidence** and from a **reactive posture to a proactive strategy**.

5.1: Scenario-Based Takeaways – SMB Phishing and Credential Compromise

In this demonstration, the *OPS-02 Phishing and Credential Theft* scenario revealed an annualized tail loss (p95) of approximately \$682,000—a significant exposure for a small or mid-sized business.

For organizations with limited resources and shared IT responsibilities, these results point toward concrete next steps:

- **Business Executives** – Evaluate the adequacy of existing **cyber-insurance coverage** based on modeled exposure. A p95 value in the hundreds of thousands signals that current limits may be insufficient.
- **GRC Analysts and Risk Managers** – Review **authentication and access-control policies** and enforce multi-factor authentication (MFA) across all user accounts and remote services.
- **IT and Security Teams** – Prioritize investment in **email security, endpoint protection**, and **user awareness training** to reduce the frequency of credential theft.
- **Compliance and Audit Personnel** – Archive simulation artifacts (CSV and JSON) as **evidence of quantitative risk assessment**, aligning with NIST SP 800-53 RA-3 and ISO 27005 documentation practices.

These actions close the loop between model output and operational response, turning simulated risk into tangible risk-reduction activities.

5.2 Audience-Aligned Value Propositions

RiskQuant directly addresses the pain points each audience faces in the cyber-risk management process:

Audience	Pain Point	How RiskQuant Adds Value
Executives	Need a clear, defensible justification for cybersecurity budgets	Converts technical probabilities into financial terms —EAL, median, and tail loss—for confident budget and insurance decisions
Risk & GRC Analysts	Difficulty linking qualitative frameworks (NIST, ISO) with quantitative models	Bridges subjective ratings with Monte Carlo simulation , harmonizing compliance and analytics
IT Security Teams	Limited visibility into which threats pose the most significant financial risk	Prioritizes vulnerabilities by potential loss impact , not just likelihood or CVSS score
Auditors & Compliance Teams	Need traceable, repeatable evidence of assessments	Produces exportable, audit-ready records (CSV + JSON) with complete parameter transparency

By aligning data science with governance needs, RiskQuant transforms complex simulations into a **shared language for decision-making**.

5.3 What's Next – Expanding the RiskQuant Scenario Series

This SMB-focused case study is the first in a three-part demonstration series designed to show how RiskQuant scales across organizational maturity levels—from lean operations with limited cybersecurity resources to complex global enterprises managing multi-tier vendor ecosystems.

Upcoming scenarios include:

- **Mid-Market Scenario: Vendor Supply-Chain Compromise → Business Disruption**
 - In this scenario, a regional company faces operational and compliance fallout when a trusted vendor suffers a ransomware breach. Viewers will

explore how RiskQuant models vendor dependencies, compares internal and third-party exposure, and quantifies business interruption risk.

- **Enterprise Scenario: Global SaaS Vendor Outage & Data Breach → Portfolio Shock**
 - Modeled on recent high-profile cloud disruptions, this advanced scenario examines how cascading SaaS failures can impact global operations, revenue, and regulatory posture. It demonstrates how RiskQuant's Monte Carlo engine scales to enterprise complexity—revealing tail losses in the tens or hundreds of millions and enabling executives to plan for low-probability, high-impact events.

Each successive demonstration will introduce greater analytical depth, larger datasets, and more sophisticated use of dashboard features—illustrating how the same intuitive interface adapts seamlessly from SMB to multinational enterprise.

Continue exploring the RiskQuant Demonstration Series to see how data-driven risk modeling supports better decision-making across every business scale. Each scenario showcases a distinct use case—SMB resilience, Mid-Market supply-chain risk, and Enterprise-scale operational continuity—inviting GRC professionals, executives, and analysts to discover how quantitative methods can transform uncertainty into insight.

Author's Note

This SMB risk quantification demonstration represents a culmination of my ongoing transition from a decade in technical marketing, product storytelling, and solution consulting into a cybersecurity career focused on **Governance, Risk & Compliance (GRC)** and **quantitative risk analysis**. Over the past several years, I have dedicated myself to developing the skills, mindset, and technical expertise required to support organizations facing increasingly complex regulatory, operational, and cyber risk challenges.

My background in building high-fidelity product simulations, crafting clear technical narratives, and enabling decision-makers strongly shaped the structure of this work. I approached each scenario—as well as the design of RiskQuant itself—with the same principles I relied on when creating enterprise demos for Microsoft and other global technology organizations: clarity, accuracy, purposeful storytelling, and a deep empathy for the professionals who must translate risk into action.

This document also reflects the knowledge and discipline I gained through my **B.S. and M.S. in Cybersecurity and Information Assurance at Western Governors University**, along with the frameworks I studied while pursuing certifications such as SecurityX, Security+, CySA+, PenTest+, Project+, SSCP, CCSP, CISSP, and CISM. These academic and professional experiences informed how I structured risk registers, modeled likelihood and impact, justified loss parameters, and aligned scenarios with frameworks such as **HIPAA, HITECH, NIST CSF, NIST SP 800-30, SP 800-53**, and industry breach data.

RiskQuant itself demonstrates the intersection of several capabilities I bring to a GRC or risk-focused role:

- **Python development** and the ability to translate risk frameworks into quantitative models
- **AI-assisted application design** that accelerates innovation and improves clarity
- **Data visualization and dashboard UX** rooted in enterprise-grade presentation standards
- **Regulatory reasoning** that maps simulation outputs to compliance and audit narratives
- **Technical communication** that bridges executives, engineers, clinicians, and legal teams
- **Risk storytelling** that makes complex concepts intelligible, defensible, and actionable

My purpose in creating this enterprise healthcare demonstration is twofold:

RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·
[linkedin.com/in/bryonmaschercybersec](https://www.linkedin.com/in/bryonmaschercybersec) · github.com/DigiFenix777

- **To show how quantitative methods—such as Monte Carlo simulation—can transform the way organizations evaluate cybersecurity and operational risk.**
- **To demonstrate the skills, judgment, and analytical approach I would bring to a GRC, risk management, or cybersecurity strategy team.**

The four scenarios in this document reflect real pressures faced by health systems: PHI exposure pathways, identity compromise, vendor ecosystem risks, and catastrophic downtime. My goal was to present these issues with the depth and professionalism they deserve—grounded in data, enriched with regulatory context, and delivered in a format accessible to executives, cybersecurity practitioners, auditors, compliance officers, and operational leaders.

Ultimately, this project is not just a demo.

It is a representation of how I work:

Analytically, collaboratively, creatively, and with an uncompromising focus on clarity and measurable impact.

I view RiskQuant as both an educational artifact and a demonstration of capability—evidence that curiosity, discipline, and thoughtful use of AI can transform a complex idea into a rigorous, enterprise-caliber product. My goal is to bring that same mindset, drive, and craftsmanship to the organizations I support in my cybersecurity career.

— Bryon Mascher

GitHub: github.com/DigiFenix777

LinkedIn: linkedin.com/in/bryonmaschercybersec

Date: November 2025

Section 6: Sources

[1] Verizon Business. (2024). *2024 Data Breach Investigations Report (DBIR)*. Verizon Communications.

[2] IBM Security. (2024). *Cost of a Data Breach Report 2024*. IBM Corporation & Ponemon Institute.

[3] Datto. (2023). *2023 Global State of the SMB Cybersecurity Report*. Datto, Inc.

[4] ENISA (European Union Agency for Cybersecurity). (2024). *ENISA Threat Landscape 2024 Report*.

[5] National Institute of Standards and Technology (NIST). (2020). *SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations*.

[6] National Institute of Standards and Technology (NIST). (2018). *SP 800-37 Rev. 2: Risk Management Framework for Information Systems and Organizations*.

[7] ISO. (2018). *ISO/IEC 27005:2018 – Information technology – Security techniques – Information security risk management*.